

# Secure Trust On First Use for Enterprise Wi-Fi: Design Guidelines and Linux Implementation

**Rathan Appana** `rathan.appana@student.kuleuven.be`

Mathy Vanhoef `mathy.vanhoef@kuleuven.be`

DistriNet, KU Leuven, Belgium

ACM WiSec '26 · July 1, 2026 · Saarbrücken, Germany



# Motivation: Enterprise Wi-Fi Under Threat

## The Scale

- Used everywhere
- 802.1X/EAP-PEAP
- AS presents an X.509 certificate

# Motivation: Enterprise Wi-Fi Under Threat

## The Scale

- Used everywhere
- 802.1X/EAP-PEAP
- AS presents an X.509 certificate

## Validation is Routinely Skipped

- Many guides **disable** the certificate verification<sup>1</sup>
- **1 in 5 devices** leaked credentials<sup>2</sup>

---

<sup>1</sup>Man Hong Hue et al. (2021). "All your Credentials are Belong to Us: On Insecure WPA2-Enterprise Configurations". In: [ACM CCS](#)

<sup>2</sup>Rathan Appana et al. (2025). "Measuring and Preventing Certificate Misconfigurations in Enterprise WPA2/3 Networks". In: [CSNet](#)

# Motivation: Enterprise Wi-Fi Under Threat

## The Scale

- Used everywhere
- 802.1X/EAP-PEAP
- AS presents an X.509 certificate

## Validation is Routinely Skipped

- Many guides **disable** the certificate verification<sup>1</sup>
- **1 in 5 devices** leaked credentials<sup>2</sup>

## Evil Twin Attack

- 1 Broadcasts the same SSID
- 2 Client skips certificate validation
- 3 MS-CHAPv2 exchange captured<sup>3</sup>
- 4 Recover password offline

<sup>1</sup> Man Hong Hue et al. (2021). "All your Credentials are Belong to Us: On Insecure WPA2-Enterprise Configurations". In: *ACM CCS*

<sup>2</sup> Rathan Appana et al. (2025). "Measuring and Preventing Certificate Misconfigurations in Enterprise WPA2/3 Networks". In: *CSNet*

<sup>3</sup> MM Marlinspike et al. (2012). "Defeating PPTP VPNs and WPA2 enterprise with MS-CHAPv2". In: *Defcon, July*

# Motivation: Enterprise Wi-Fi Under Threat

## The Scale

- Used everywhere
- 802.1X/EAP-PEAP
- AS presents an X.509 certificate

## Validation is Routinely Skipped

- Many guides **disable** the certificate verification<sup>1</sup>
- **1 in 5 devices** leaked credentials<sup>2</sup>

## Evil Twin Attack

- 1 Broadcasts the same SSID
- 2 Client skips certificate validation
- 3 MS-CHAPv2 exchange captured<sup>3</sup>
- 4 Recover password offline

## Trust On First Use (TOFU)

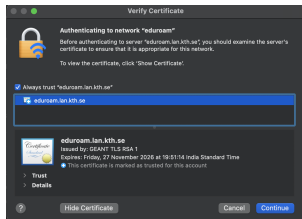
- User approves cert on first connection; **pinned** after
- No prior configuration required

<sup>1</sup> Man Hong Hue et al. (2021). "All your Credentials are Belong to Us: On Insecure WPA2-Enterprise Configurations". In: *ACM CCS*

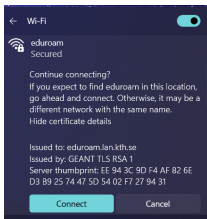
<sup>2</sup> Rathan Appana et al. (2025). "Measuring and Preventing Certificate Misconfigurations in Enterprise WPA2/3 Networks". In: *CSNet*

<sup>3</sup> MM Marlinspike et al. (2012). "Defeating PPTP VPNs and WPA2 enterprise with MS-CHAPv2". In: *Defcon, July*

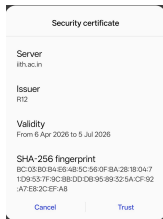
# What is TOFU? How does it look like?



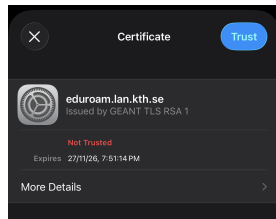
macOS



Windows



Android



iOS

# Our Contributions

- 1 **Empirical analysis** of TOFU across Android, iOS, macOS, and Windows

# Our Contributions

- 1 **Empirical analysis** of TOFU across Android, iOS, macOS, and Windows
- 2 **Vulnerability disclosures** two patches merged into wpa\_supplicant upstream; issues reported to Apple, Google, and Microsoft

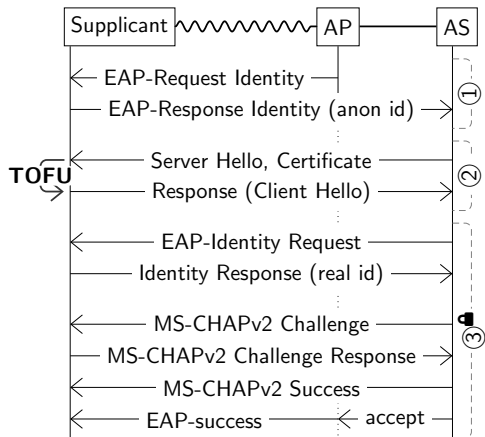
# Our Contributions

- 1 **Empirical analysis** of TOFU across Android, iOS, macOS, and Windows
- 2 **Vulnerability disclosures** two patches merged into wpa\_supplicant upstream; issues reported to Apple, Google, and Microsoft
- 3 **Design guidelines** for secure TOFU implementation

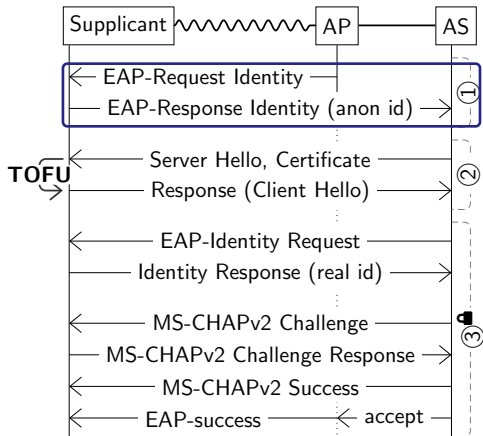
# Our Contributions

- 1 **Empirical analysis** of TOFU across Android, iOS, macOS, and Windows
- 2 **Vulnerability disclosures** two patches merged into wpa\_supplicant upstream; issues reported to Apple, Google, and Microsoft
- 3 **Design guidelines** for secure TOFU implementation
- 4 **First TOFU implementation on Linux** released as open-source

## Background: WPA-Enterprise Authentication



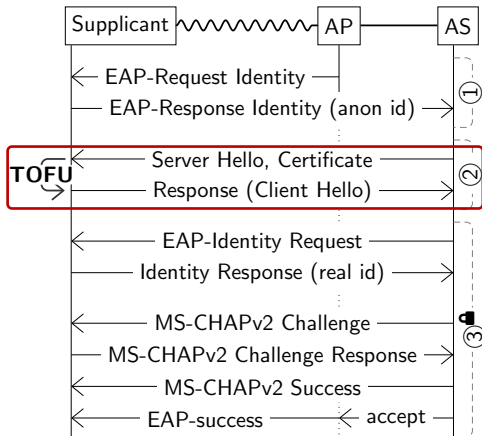
# Background: WPA-Enterprise Authentication



## ① Discovery & Association

Client sends an 'Anonymous ID'

# Background: WPA-Enterprise Authentication



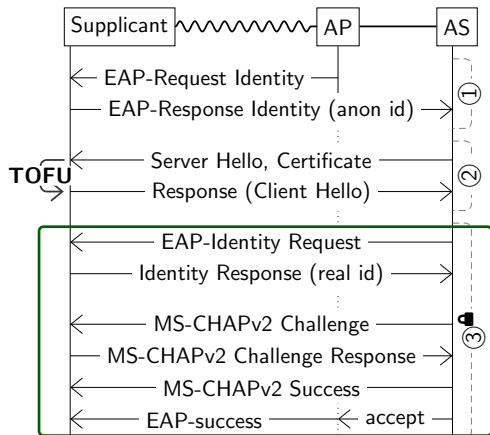
## ① Discovery & Association

Client sends an 'Anonymous ID'

## ② TLS Tunnel Establishment

AS presents its X.509 certificate  
TOFU operates here

# Background: WPA-Enterprise Authentication



## ① Discovery & Association

Client sends an 'Anonymous ID'

## ② TLS Tunnel Establishment

AS presents its X.509 certificate  
TOFU operates here

## ③ Inner Authentication

Credentials exchanged inside the TLS tunnel.

Security relies entirely on certificate validation in ②.

# Empirical Analysis: Results

4 platforms · 12 behavioral dimensions · controlled hostapd AP · PEAP/MSCHAPv2

|         | UI<br>Fields | Exp Cert<br>(New) | Exp Cert<br>(Known) | Outer<br>ID | No.<br>Conn | CA<br>Pre-trusted | Cert<br>Detail | Wrong<br>User | Wrong<br>Pass | CA<br>Rotation | AS<br>Rotation | Chain<br>Shown |
|---------|--------------|-------------------|---------------------|-------------|-------------|-------------------|----------------|---------------|---------------|----------------|----------------|----------------|
| Android | Partial      | Rejected*         | Accepted            | Mixed       | 2*          | Not shown         | Partial        | No feedback   | No feedback   | Prompted*      | Silent*        | Partial        |
| macOS   | Partial      | Accepted          | Accepted            | Real        | 1           | Indicated*        | Full*          | No feedback   | No feedback   | Prompted*      | Prompted       | Full           |
| iOS     | Partial      | Accepted          | Accepted            | Real        | 1           | Indicated*        | Full*          | No feedback   | No feedback   | Prompted*      | Prompted       | Partial        |
| Windows | Partial      | Rejected*         | Accepted            | Real        | 1           | Not shown         | Partial        | No feedback   | No feedback   | Rejected       | Rejected       | Partial        |

 Secure behavior    Insecure behavior    Partial / ambiguous   \* Behavior adopted in our design

# Empirical Analysis: Results

4 platforms · 12 behavioral dimensions · controlled hostapd AP · PEAP/MSCHAPv2

|         | UI Fields | Exp Cert (New) | Exp Cert (Known) | Outer ID | No. Conn | CA Pre-trusted | Cert Detail | Wrong User  | Wrong Pass  | CA Rotation | AS Rotation | Chain Shown |
|---------|-----------|----------------|------------------|----------|----------|----------------|-------------|-------------|-------------|-------------|-------------|-------------|
| Android | Partial   | Rejected*      | Accepted         | Mixed    | 2*       | Not shown      | Partial     | No feedback | No feedback | Prompted*   | Silent*     | Partial     |
| macOS   | Partial   | Accepted       | Accepted         | Real     | 1        | Indicated*     | Full*       | No feedback | No feedback | Prompted*   | Prompted    | Full        |
| iOS     | Partial   | Accepted       | Accepted         | Real     | 1        | Indicated*     | Full*       | No feedback | No feedback | Prompted*   | Prompted    | Partial     |
| Windows | Partial   | Rejected*      | Accepted         | Real     | 1        | Not shown      | Partial     | No feedback | No feedback | Rejected    | Rejected    | Partial     |

 Secure behavior    Insecure behavior    Partial / ambiguous   \* Behavior adopted in our design

macOS & iOS: accept expired certificates on first connection

- Display expiry warning but allow user to proceed, certificate accepted regardless

# Empirical Analysis: Results

4 platforms · 12 behavioral dimensions · controlled hostapd AP · PEAP/MSCHAPv2

|         | UI Fields | Exp Cert (New) | Exp Cert (Known) | Outer ID | No. Conn | CA Pre-trusted | Cert Detail | Wrong User  | Wrong Pass  | CA Rotation | AS Rotation | Chain Shown |
|---------|-----------|----------------|------------------|----------|----------|----------------|-------------|-------------|-------------|-------------|-------------|-------------|
| Android | Partial   | Rejected*      | Accepted         | Mixed    | 2*       | Not shown      | Partial     | No feedback | No feedback | Prompted*   | Silent*     | Partial     |
| macOS   | Partial   | Accepted       | Accepted         | Real     | 1        | Indicated*     | Full*       | No feedback | No feedback | Prompted*   | Prompted    | Full        |
| iOS     | Partial   | Accepted       | Accepted         | Real     | 1        | Indicated*     | Full*       | No feedback | No feedback | Prompted*   | Prompted    | Partial     |
| Windows | Partial   | Rejected*      | Accepted         | Real     | 1        | Not shown      | Partial     | No feedback | No feedback | Rejected    | Rejected    | Partial     |

 Secure behavior    Insecure behavior    Partial / ambiguous   \* Behavior adopted in our design

All four platforms accept expired certificates on known networks

- None re-validate expiry after initial trust decision
- wpa\_supplicant: checks bypassed when no CA configured or only AS cert pinned, **reported and patched upstream**

# Empirical Analysis: Results

4 platforms · 12 behavioral dimensions · controlled hostapd AP · PEAP/MSCHAPv2

|         | UI Fields | Exp Cert (New) | Exp Cert (Known) | Outer ID | No. Conn | CA Pre-trusted | Cert Detail | Wrong User  | Wrong Pass  | CA Rotation | AS Rotation | Chain Shown |
|---------|-----------|----------------|------------------|----------|----------|----------------|-------------|-------------|-------------|-------------|-------------|-------------|
| Android | Partial   | Rejected*      | Accepted         | Mixed    | 2*       | Not shown      | Partial     | No feedback | No feedback | Prompted*   | Silent*     | Partial     |
| macOS   | Partial   | Accepted       | Accepted         | Real     | 1        | Indicated*     | Full*       | No feedback | No feedback | Prompted*   | Prompted    | Full        |
| iOS     | Partial   | Accepted       | Accepted         | Real     | 1        | Indicated*     | Full*       | No feedback | No feedback | Prompted*   | Prompted    | Partial     |
| Windows | Partial   | Rejected*      | Accepted         | Real     | 1        | Not shown      | Partial     | No feedback | No feedback | Rejected    | Rejected    | Partial     |

 Secure behavior    Insecure behavior    Partial / ambiguous   \* Behavior adopted in our design

## Android: anonymous identity sent without realm

- On the first connection, ID  $\Rightarrow$  **Anonymous** is used
- **Android bug**: Without realm  $\Rightarrow$  connection fails on eduroam like networks
- On reconnects, **real identity** transmitted in unencrypted Phase ①

# Empirical Analysis: Results

4 platforms · 12 behavioral dimensions · controlled hostapd AP · PEAP/MSCHAPv2

|         | UI Fields | Exp Cert (New) | Exp Cert (Known) | Outer ID | No. Conn | CA Pre-trusted | Cert Detail | Wrong User  | Wrong Pass  | CA Rotation | AS Rotation | Chain Shown |
|---------|-----------|----------------|------------------|----------|----------|----------------|-------------|-------------|-------------|-------------|-------------|-------------|
| Android | Partial   | Rejected*      | Accepted         | Mixed    | 2*       | Not shown      | Partial     | No feedback | No feedback | Prompted*   | Silent*     | Partial     |
| macOS   | Partial   | Accepted       | Accepted         | Real     | 1        | Indicated*     | Full*       | No feedback | No feedback | Prompted*   | Prompted    | Full        |
| iOS     | Partial   | Accepted       | Accepted         | Real     | 1        | Indicated*     | Full*       | No feedback | No feedback | Prompted*   | Prompted    | Partial     |
| Windows | Partial   | Rejected*      | Accepted         | Real     | 1        | Not shown      | Partial     | No feedback | No feedback | Rejected    | Rejected    | Partial     |

 Secure behavior    Insecure behavior    Partial / ambiguous   \* Behavior adopted in our design

## iOS & macOS: over-aggressive pinning

- TOFU triggered on *any* certificate change, including leaf-only rotation

# Empirical Analysis: Results

4 platforms · 12 behavioral dimensions · controlled hostapd AP · PEAP/MSCHAPv2

|         | UI Fields | Exp Cert (New) | Exp Cert (Known) | Outer ID | No. Conn | CA Pre-trusted | Cert Detail | Wrong User  | Wrong Pass  | CA Rotation | AS Rotation | Chain Shown |
|---------|-----------|----------------|------------------|----------|----------|----------------|-------------|-------------|-------------|-------------|-------------|-------------|
| Android | Partial   | Rejected*      | Accepted         | Mixed    | 2*       | Not shown      | Partial     | No feedback | No feedback | Prompted*   | Silent*     | Partial     |
| macOS   | Partial   | Accepted       | Accepted         | Real     | 1        | Indicated*     | Full*       | No feedback | No feedback | Prompted*   | Prompted    | Full        |
| iOS     | Partial   | Accepted       | Accepted         | Real     | 1        | Indicated*     | Full*       | No feedback | No feedback | Prompted*   | Prompted    | Partial     |
| Windows | Partial   | Rejected*      | Accepted         | Real     | 1        | Not shown      | Partial     | No feedback | No feedback | Rejected    | Rejected    | Partial     |

 Secure behavior    Insecure behavior    Partial / ambiguous   \* Behavior adopted in our design

## Windows: silent rejection on cert rotation

- Silently rejects rotated certificates ⇒ connection drops with no feedback

# Proposed Design Guidelines for Secure TOFU

## 1 Configurable Trust

TOFU offered alongside manual CA configuration

## 2 System Trust Store Verification

Check against OS CA bundle before prompting; display result

## 3 Minimal Trust Prompt

Show SSID, CN, server DNS, CA disclaimer; advanced details expandable

## 4 Anonymous Identity Support

Auto-derive anonymous@realm from user@realm

## 5 Trust Anchor: CA + Domain

Pin CA certificate and leaf domain, not the leaf certificate itself

## 6 Certificate Change Handling

Silent reconnect if domain unchanged; new prompt only if CA rotates

## 7 Expiry Checks on Every Connection

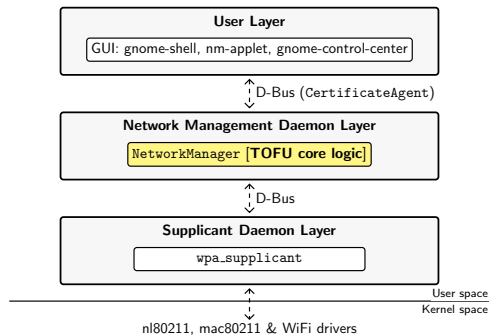
Re-validate certificate expiry on each connection attempt

## 8 Granular Error Reporting

Distinguish: expired cert / wrong username / wrong password

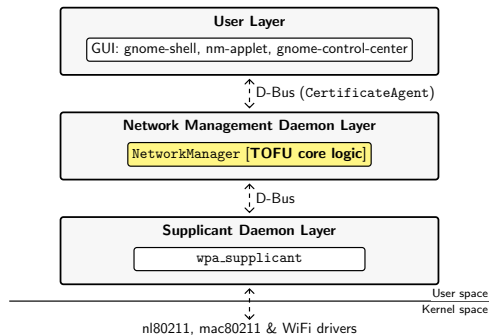
# Linux Proof-of-Concept: Architecture

- Three-layer user-space architecture communicating via **D-Bus**



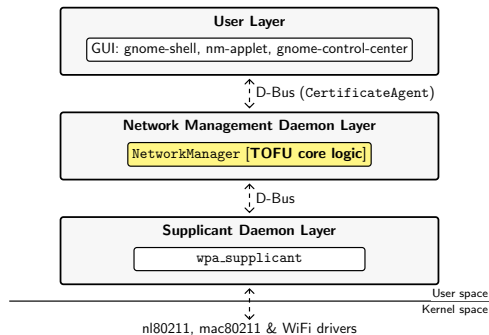
# Linux Proof-of-Concept: Architecture

- Three-layer user-space architecture communicating via **D-Bus**
- Implemented within the NetworkManager daemon



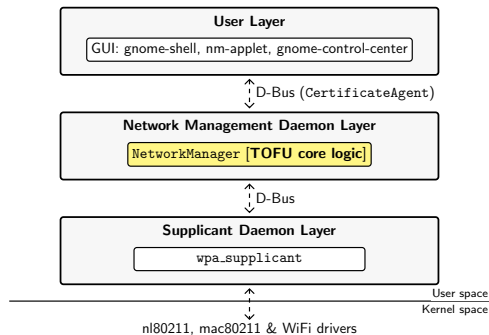
# Linux Proof-of-Concept: Architecture

- Three-layer user-space architecture communicating via **D-Bus**
- Implemented within the NetworkManager daemon
- New CertificateAgent D-Bus interface(gnome-shell, nm-applet, nmtui, gnome-control-center)

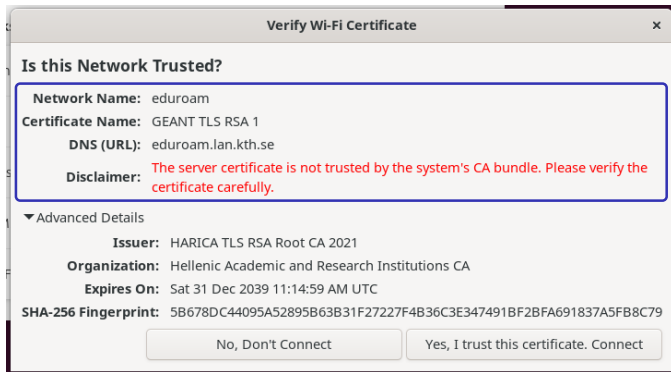


# Linux Proof-of-Concept: Architecture

- Three-layer user-space architecture communicating via **D-Bus**
- Implemented within the NetworkManager daemon
- New CertificateAgent D-Bus interface (gnome-shell, nm-applet, nmtui, gnome-control-center)
- **Open-source:**  
<https://github.com/rathanappana/NetworkManager-TOFU>
- Plan to submit upstream



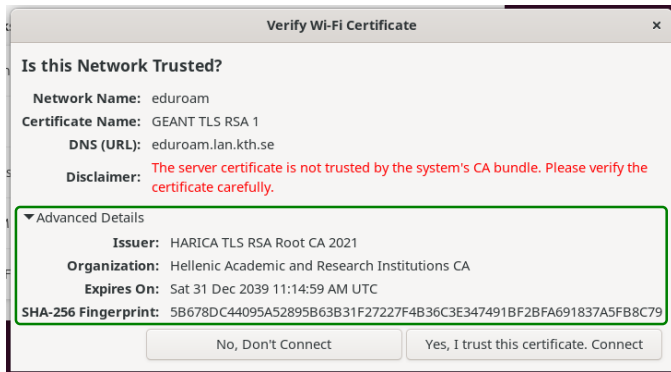
# Linux Proof-of-Concept: User Interface



Minimal details

Typical user

# Linux Proof-of-Concept: User Interface



Advanced details

Expert user

# Evaluation

## Experimental Setup

### ■ Testing

#### **Simulated:**

mac80211\_hwsim kernel  
module

#### **Real networks:**

eduroam, IITH, KU Leuven

- Ubuntu 24.04.1 LTS
- Kernel 6.17.0
- NetworkManager 1.57.4-dev
- wpa\_supplicant 2.10
- nm-applet as certificate agent

| <i>Scenario</i>               | <i>Observed Behavior</i>              |
|-------------------------------|---------------------------------------|
| First connection, valid chain | Prompt shown; CA saved on accept      |
| AS rotation, same CA          | Silent connect, no prompt             |
| CA rotation                   | New prompt triggered                  |
| User dismisses prompt         | Session cleared; prompt on retry      |
| Anonymous identity empty      | Derived automatically                 |
| Rogue AP, expired cert        | Blocked before credentials sent       |
| Rogue AP, cert mismatch       | Warning prompt; no credentials sent   |
| Leaf cert only (no chain)     | Fingerprint pinned to connection UUID |
| Cert trusted by system CA     | Trusted disclaimer displayed          |
| eduroam, IITH, KU Leuven      | Prompt on first use; silent reconnect |

All scenarios behaved as specified. Evil Twin attacks were blocked in every case before credential submission.

# Limitations

## Limitations

- First-use trust remains vulnerable
- Custom outer identities require manual configuration
- No certificate revocation support (CRL/OCSP)

# Conclusion

## Conclusion

- First open-source TOFU implementation for Linux Wi-Fi
- Protects against Evil Twin attacks after initial trust
- Provides deployment guidelines for broader adoption

# Thank You

## Questions & Discussion

**Paper DOI:** <https://dl.acm.org/doi/10.1145/3765613.3811682>

**Code:** <https://github.com/rathanappana/NetworkManager-T0FU>

**Contact:** [rathan.appana@student.kuleuven.be](mailto:rathan.appana@student.kuleuven.be)

